HairMela Security and Data Protection Audit

Final project report: NIST CSF 2.0 and NDPA 2023

Ayeni Ayomide, Cybersecurity Trainee (SIWES), Axiahub

October 2026

1. Executive summary

This project assessed the security and data protection practices of **HairMela** (hairmela.com), a salon walk-in queue app. It was done with HairMela's written permission, using public information, the app as a normal customer, and a survey answered by HairMela's management. No scanning, testing or access to systems or customer data took place.

Result. Based on management's answers, HairMela scores **98%, which is Strong**. Of 25 checklist controls, 21 could be assessed: 20 are Implemented (as reported by management), 1 is Partial, none were found missing, and 4 could not be assessed because the survey did not ask about them.

Area	Score	Band
Govern and Identify	100%	Strong
Protect	94%	Strong
Detect	100%	Strong
Respond and Recover	100%	Strong
Privacy duties (NDPA)	100%	Strong
Overall	**98%**	**Strong**

Important. This is a *management-reported* result. The scores rest on HairMela management's own answers, which were trusted as given, and documents were not seen. What could be checked directly, the public pages and the app, is thinner than management reports in several places (see section 5). Those are treated as follow-ups, not as reasons to change the score.

Risks. No risk is Critical. One is High (R-07, a breach that is not noticed, recorded or reported in time). Eight are Medium and five are Low. The priorities are to test and write down the breach plan, and to make the public pages match practice: a consent line and privacy link at sign-up, customer rights, retention periods, named vendors, and a rule for public Wi-Fi.

2. Introduction

HairMela lets customers join a salon's walk-in queue from their phone. It handles personal data (names, emails, optional phone numbers, queue history), so it must protect that data and respect customers' rights under Nigerian law.

The objectives were to: (1) assess current practice against recognised frameworks; (2) rate the risks; (3) recommend simple, affordable fixes; (4) produce policies and an awareness flyer; and (5) measure whether awareness improves.

3. Scope, permission and ethics

HairMela gave written permission (email and WhatsApp, see the evidence file) with these limits:

- Public information only, plus the app used as a normal customer.
- A voluntary survey for HairMela's management.
- **No** scanning, penetration testing, or access to systems or customer data.

Ethical handling:

- The survey collects no customer details or passwords.

- Raw responses are **not published**. Answers are kept confidential and reported as a summary.
- Screenshots were redacted before inclusion (email addresses and HairMela's contact number covered).
- HairMela's replies to this audit stay confidential to the project.

4. Methodology

1. **Permission** obtained and limits recorded.
2. **Public documents** reviewed: privacy policy, terms of use and the delete-account page.
3. **App review** as a normal customer: sign-up, profile, settings.
4. **Management survey** (Google Form, 20 practice questions and a confidence rating) answered by HairMela's management. Answers were trusted as given.
5. **Scoring** of a 25-control checklist mapped to NIST CSF 2.0 and the NDPA 2023.
6. **Risk assessment** using Risk = Likelihood × Impact.
7. **Action plan, policies and awareness flyer**, then a follow-up survey to measure change.

Control scoring. Implemented = 2, Partial = 1, Not implemented = 0. Score % = points earned ÷ (controls assessed × 2). Controls the survey did not ask about are left out. Bands: Strong 80% or more, Developing 50 to 79%, Weak under 50%. These cut-offs are a working assumption for a small business. "Implemented" means management reported it; documents were not seen.

Worked example. 21 controls assessed means 42 points possible. 20 Implemented give 40 points and 1 Partial gives 1 point. That is 41 out of 42, or 98%.

Risk scoring. Likelihood and Impact each rated 1 to 5. Low 1 to 4, Medium 5 to 9, High 10 to 15, Critical 16 to 25.

5. Findings

5.1 Public policy documents

Does well: plain, readable language; collects little data (name, email, optional phone); states it does not sell personal data; Meta Pixel only after opt-in cookie consent; a clear deletion page with a 30-day timeline; push notifications are opt-in.

Thin or missing: no mention of the NDPA or the regulator (NDPC); consent assumed from using the site; withdrawing consent means leaving the service; no listed rights to access, correct or complain; retention is "as long as needed"; roles of HairMela and the salons not spelled out; no breach statement; vendors unnamed. The policy and deletion page also give a different contact address from the website footer, so HairMela should confirm which one is monitored.

5.2 The app, used as a normal customer

Seen: editable profile with optional nickname and phone; other customers' names are not shown on the site; Settings shows email-verified status; password reset by emailed link; Google account link shown; notifications off until turned on; an in-app help guide.

Gaps: no privacy policy link inside the app; no delete-account option in the app (deletion is by contacting HairMela). The sign-up screen shows no consent line or policy link beside the button, and the phone field has no "optional" label although the policy calls it optional. A Google sign-up sent no separate verification email, which is expected because Google has already verified the address; sign-up with email and password was not tested.

5.3 Management survey baseline

HairMela's management answered the survey and rated confidence in the company's data protection **5 out of 5**. Answers, taken as given:

Topic	Management answer
Own login; access limited to the job; access removed on exit	Yes
Strong passwords and two-step sign-in	Yes
Devices protected and kept updated	Yes
Customer details kept off personal WhatsApp and phones	Yes, kept off

Backups, with a tested restore	Yes
Incident record kept; knows when to report a breach	Yes
Security training and a written policy	Yes
Privacy notice, consent, customer requests, retention	Yes
Written agreements with vendors	Yes
Public Wi-Fi avoided for work	Partly

These are self-reported. Free-text interview questions were not answered.

5.4 Management says, the pages show

Control	Management says	Public pages and app show
Privacy notice	Clear notice given	Plain notice; lists no rights, names no controller, no NDPA mention
Consent	Consent is asked	Consent assumed from use; only cookies are opt-in; no consent line beside the sign-up button
Customer requests	Clear process in place	Deletion within 30 days; no route to ask for a copy of data; no delete option in the app
Retention	Known and followed	“As long as needed”; no fixed periods
Vendor agreements	Written agreements exist	Providers mentioned but not named
Breach reporting	Knows when and how	Nothing stated publicly

The score follows management’s answers. These differences are listed as follow-ups: the public wording should match what the business really does.

5.5 Scorecard

The full 25-control checklist with status, basis and framework mapping is in Appendix A.

6. Risk assessment

Risk	Description	L	I	Score	Rating
R-01	Staff account taken over through weak or reused passwords	2	4	8	Medium
R-02	Phishing message tricks staff into giving access	2	4	8	Medium
R-03	Customer details shared on personal chats or phones	1	3	3	Low
R-04	Shared accounts hide who did what	1	3	3	Low
R-05	Former staff or contractors keep access	1	4	4	Low
R-06	Lost or stolen unlocked device exposes data	1	4	4	Low
R-07	Breach not noticed, recorded or reported in time	2	5	10	High
R-08	Customer request to	2	3	6	Medium

	see, fix or delete data mishandled				
R-09	Vendor mishandles data, no written agreement	2	4	8	Medium
R-10	Data lost because backups were never tested	1	5	5	Medium
R-11	Data kept far longer than needed	2	2	4	Low
R-12	Untrained staff do not know what to do in an incident	2	3	6	Medium
R-13	Consent and privacy policy not clearly shown at sign-up	3	3	9	Medium
R-14	Work on public Wi-Fi exposes data	3	3	9	Medium

Why the highest are rated this way.

- **R-07 (High):** management reports an incident register and reporting steps, but the public pages say nothing on breaches, and the impact of a missed breach would be severe.
- **R-13 and R-14 (9):** the sign-up page shows no consent line or privacy link; management answered “Partly” on avoiding public Wi-Fi.
- **R-01, R-02 and R-09 (8):** management reports the controls in place, but the impact of failure would be major. Likelihood is kept low because they are reported as in place.
- **R-03 to R-06 and R-11 are Low** because management reports the matching controls in place.

Ratings rest on management’s answers, the public pages and the app, and may change as more evidence arrives.

7. Recommendations and action plan

Priority	Risks	Action
1. Fix first (High)	R-07	Test the breach plan and write it down on one page, with an incident log
2. Quick fixes (Medium, low cost)	R-13	Add a consent line and privacy link at sign-up (a text edit; do it first)
	R-08	Publish clear steps for customer requests, list customers’ rights, and add an in-app way to request deletion or a copy of data
	R-09	Name vendors in the policy and confirm written agreements
	R-14	Set a simple rule for work on public Wi-Fi
3. Keep up and verify (Medium, already in place)	R-01	Keep two-step sign-in on staff and admin accounts
	R-02	Hold a short phishing refresher each year
	R-10	Test restoring from backup on a regular schedule
	R-12	Run refresher training for staff
Monitor (Low)	R-03, R-04, R-05, R-06, R-11	Keep current practice; publish retention periods

Other recommendations: show a privacy policy link inside the app, and confirm which contact address is monitored.

8. Policies

Five short, plain-language templates were written for HairMela's team (in the `policies/` folder):

1. Incident and breach plan with a log.
2. Customer chats and phones rule.
3. Accounts and leavers checklist.
4. Keep-and-delete (retention) table.
5. Customer requests steps.

9. Awareness campaign

A one-page flyer gives staff five habits: use strong passwords; think before you click; keep customer details out of personal chats; lock and update your devices; report problems fast, without blame. The flyer will be shared with the HairMela team after the presentation.

10. Measuring the change (post-survey plan)

The same questions will be repeated after the flyer and templates, plus questions about whether the flyer was seen and any habits changed. Results will be compared with the baseline in words. **Post-survey results are pending** and will be added as an update to this report.

11. Limitations

- Permission covered public information, the app as a customer, and a survey. No testing was done.
- The score is management-reported: answers were trusted as given and documents were not seen, so "Implemented" means management reported it.
- The public pages and app are thinner than management reports in several places (section 5.4). These are follow-ups and did not change the score.
- Four controls had no survey question and were left out of the score.
- Risk ratings are judgements and may change.
- NDPA section numbers were taken from a hosted copy of the Act and should be confirmed in the official text. This report is not legal advice.

12. Conclusion

HairMela scores 98%, Strong, as reported by its management. The basics are in place, but the score has not been confirmed with documents, and the public pages and app are thinner than management reports. The next steps are to test and write down the breach plan, add a consent line and privacy link at sign-up, publish customer rights and retention periods, name vendors, and set a public Wi-Fi rule. The follow-up survey will show whether things improve.

13. References

- NIST, *Cybersecurity Framework (CSF) 2.0*, 2024.
- Federal Republic of Nigeria, *Nigeria Data Protection Act 2023* (NDPA). Sections used: s.24 principles; s.25 lawful basis; s.26 consent; s.27 information to data subjects; s.28 impact assessment; s.29 controller and processor duties; s.31 children; s.32 data protection officer; s.34 rights of access, correction and erasure; s.39 security; s.40 breach notification (NDPC within 72 hours; tell people when risk is high); s.44 registration. Please confirm all section numbers in the official copy.
- HairMela public privacy policy, terms of use and delete-account page (reviewed 14 October 2026).

Appendix A: Control checklist

Basis: what the status is based on. Status: I = Implemented (management-reported), P = Partial, NA = Not assessed.

ID	Control	Basis	NIST · NDPA	Status
GV-01	A written security and data protection policy exists, and staff have read it.	Management answers	GV.PO · s.24	I
GV-02	A named person is responsible for data protection.	Management answers	GV.RR · s.32 where it applies	I
GV-03	Vendors that handle data have written data protection agreements.	Management answers; public pages thinner	GV.SC · s.29	I
ID-01	An inventory exists of systems, devices and where personal data lives.	No question asked	ID.AM	NA
ID-02	It is known what data is collected, why, who has access and how long it is kept.	Management answers	ID.AM · s.24	I
ID-03	Risks to personal data are assessed regularly.	No question asked	ID.RA · s.28	NA
PR-01	Each person has their own login, with no shared accounts.	Management answers	PR.AA · s.39	I
PR-02	Strong passwords and two-factor sign-in on important accounts.	Management answers	PR.AA · s.39	I
PR-03	Access is limited to what each job needs.	Management answers	PR.AA · s.39	I
PR-04	Access is removed promptly when someone leaves.	Management answers	PR.AA · s.39	I
PR-05	Staff receive security and data protection training.	Management answers	PR.AT · s.39, s.24	I
PR-06	Customer details are kept off personal WhatsApp and personal phones.	Management answers	PR.DS · s.39, s.24	I
PR-07	A retention and deletion process exists and is followed.	Management answers; public pages thinner	PR.DS · s.39, s.24	I
PR-08	Work devices have screen locks and are kept updated.	Management answers	PR.PS · s.39	I
PR-09	Public Wi-Fi is avoided for work tasks.	Management answers	PR.IR · s.39	P
DE-01	Unusual sign-ins or account activity would be noticed.	No question asked	DE.CM · s.39	NA
DE-02	Staff can spot phishing or a suspected breach and know who to tell.	Management answers	DE.AE · s.40	I
RS-01	A documented incident and breach response procedure exists.	Management answers	RS.MA · s.40	I
RS-02	A breach register records incidents, even small ones.	Management answers	RS.CO · s.40	I
RS-03	It is known when and	Management answers;	RS.CO · s.40	I

	how to report a breach to the NDPC and to customers.	public pages thinner		
RC-01	Important data is backed up, and a restore has been tested.	Management answers	RC.RP · s.39	I
NP-01	Customers see a clear privacy notice explaining how their data is used.	Management answers; public pages thinner	s.27	I
NP-02	Consent is requested where needed, and records are kept.	Management answers; public pages thinner	s.25, s.26	I
NP-03	A clear process handles customer requests to access, correct or delete their data.	Management answers; public pages thinner	s.34	I
NP-04	Duties to the regulator (NDPC), such as registration, are met where they apply.	No question asked	s.44	NA

Appendix B: Survey topics

The survey covered: consent; personal data and privacy notices; retention and customer requests; vendor agreements; access and passwords; devices and communication (including personal WhatsApp, backups and public Wi-Fi); incidents and breach reporting; training and written policies; and overall confidence (1 to 5). The follow-up survey repeats these and adds flyer feedback. Raw responses are not published, and answers are kept confidential.